



EDUCACIÓN
SECRETARÍA DE EDUCACIÓN PÚBLICA



TECNOLÓGICO
NACIONAL DE MÉXICO



Instituto Tecnológico de San Juan del Río



Tópicos de Ciberseguridad

[Hardening de windows]

P R E S E N T A:

[Oscar Alberto Leal Ramírez][22590042]

[Isaac Castro Islas][B19140346]

[Hortencia Sanchez Carlos][B23590532]

[Ingeniería en Sistemas Computacionales]

Equipo Lima

PERIODO [Enero-Junio (2026)]

REPORTE DE PRÁCTICA - HARDENING DE WINDOWS SERVER

Aseguramiento de servicios, control de accesos, conectividad segura y respaldos automatizados

1. Objetivo

El objetivo de esta práctica fue implementar un proceso de hardening sobre un servidor Windows Server 2022 con SQL Server Express, fortaleciendo la administración local, la autenticación del motor de base de datos, la asignación de permisos por usuario, el control de acceso remoto y la continuidad operativa mediante respaldos automatizados. La práctica se documentó con evidencia visual de cada fase para justificar técnicamente los cambios realizados y demostrar que cada control fue aplicado de forma ordenada y verificable.

2. Infraestructura utilizada

Componente	Descripción
Servidor principal	Windows Server 2022 virtualizado en VMware Workstation
Motor de base de datos	SQL Server Express con instancia WIN-B5N5T8LK3OI\SQLEXPRESS
Consola de administración	SQL Server Management Studio (SSMS)
Servidor Linux	Debian 12 utilizado como nodo remoto de validación y respaldo y wsl ubuntu en Windows para la ejecución ssh del server
Conectividad remota	Tailscale VPN para comunicación privada entre nodos autorizados
Almacenamiento externo	Google Drive mediante rclone para respaldo fuera de sitio

3. Desarrollo de la práctica

3.1 Acceso a Administración de equipos y revisión inicial del servidor

Como punto de partida se ingresó a la consola de Administración de equipos de Windows Server. Esta herramienta permite centralizar tareas importantes del hardening, como la revisión de usuarios locales, grupos, servicios, visor de eventos, carpetas compartidas y Programador de tareas. Para abrirla se puede usar cualquiera de las siguientes rutas: presionar Win + R y ejecutar compmgmt.msc; dar clic derecho sobre Inicio y seleccionar Administración de equipos; o abrir Server Manager y acceder desde Tools / Computer Management.

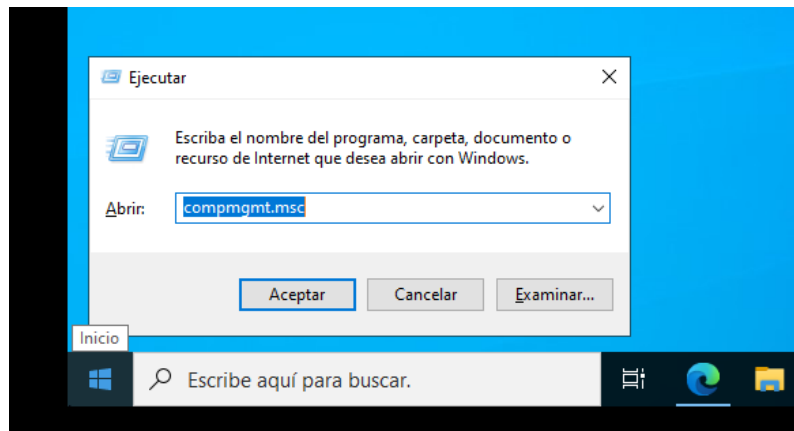


Figura 1. Ejecución del comando `compmgmt.msc` desde la ventana *Ejecutar* para abrir Administración de equipos.

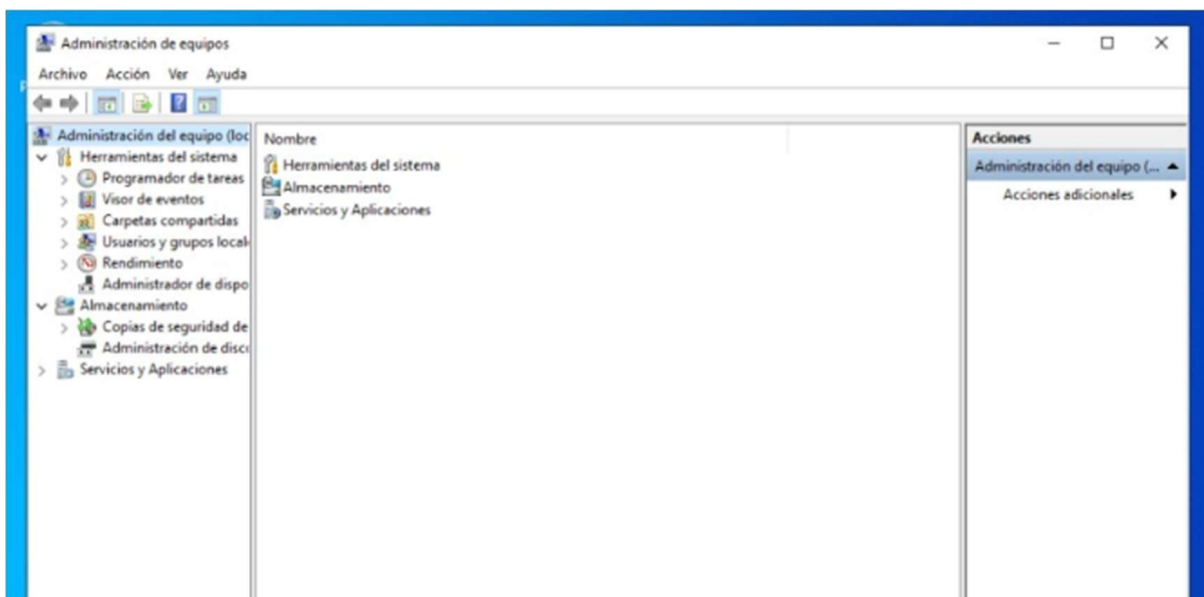


Figura 2. Vista inicial de la consola Administración de equipos para revisar herramientas del sistema.

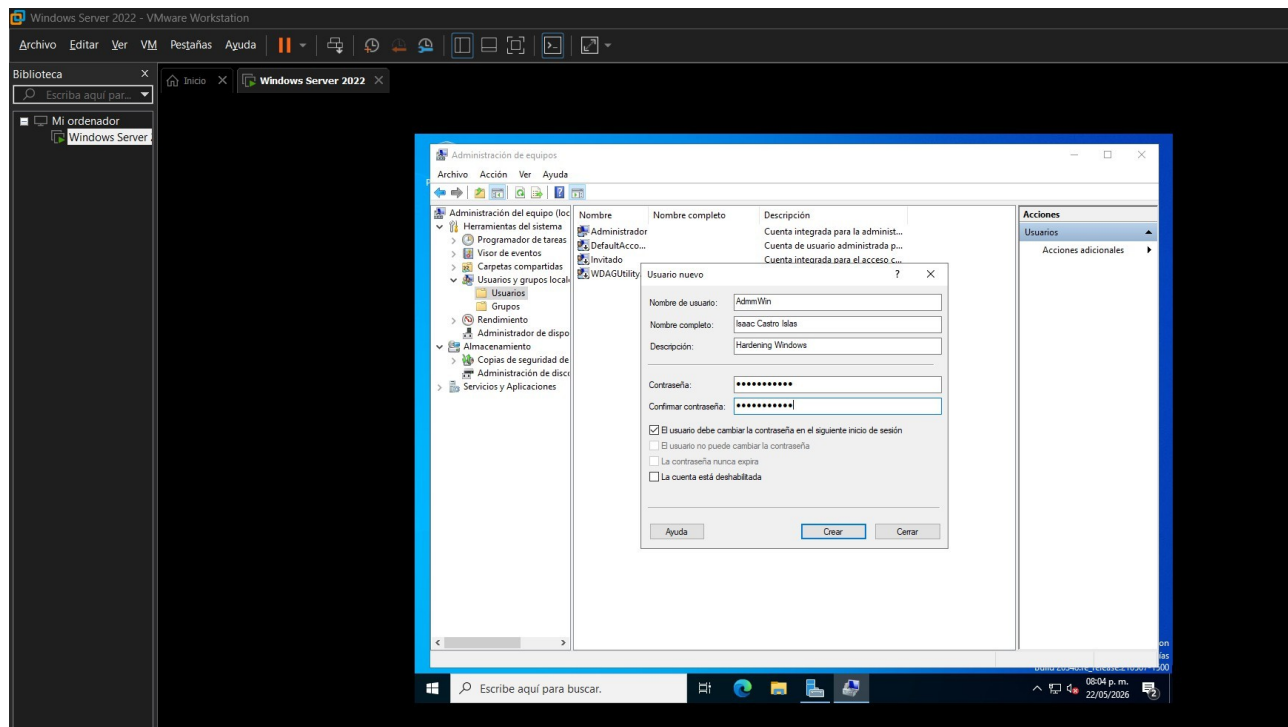


Figura 3. Creación de la cuenta de usuario local dentro de Administración de equipos.

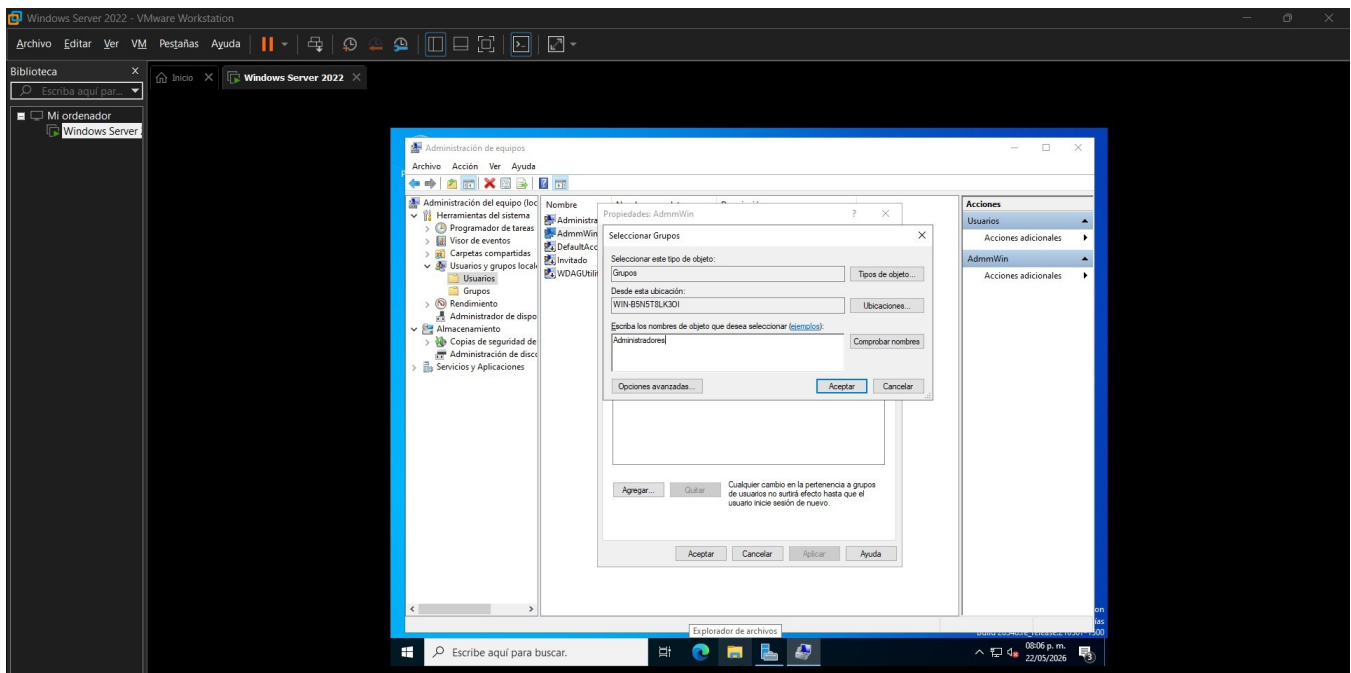


Figura 4. Asignación de la cuenta local al grupo Administradores para habilitar tareas de gestión del servidor.

Configuración del SO Base: Se procedió con la instalación de Windows Server 2022 y la posterior creación de la cuenta de usuario Administrador local, otorgándole los privilegios globales necesarios para la gestión del sistema, la configuración del *firewall* y la implementación segura del motor de base de datos SQL Server Express.

3.2 Instalación de SQL Server Express y SQL Server Management Studio

Se instaló SQL Server Express en el entorno de Windows Server para disponer de un motor de base de datos local sobre el cual aplicar controles de hardening. Durante el proceso se validó la ejecución del instalador mediante UAC y posteriormente se completó la instalación de SQL Server Management Studio, herramienta utilizada para administrar la instancia de forma gráfica.

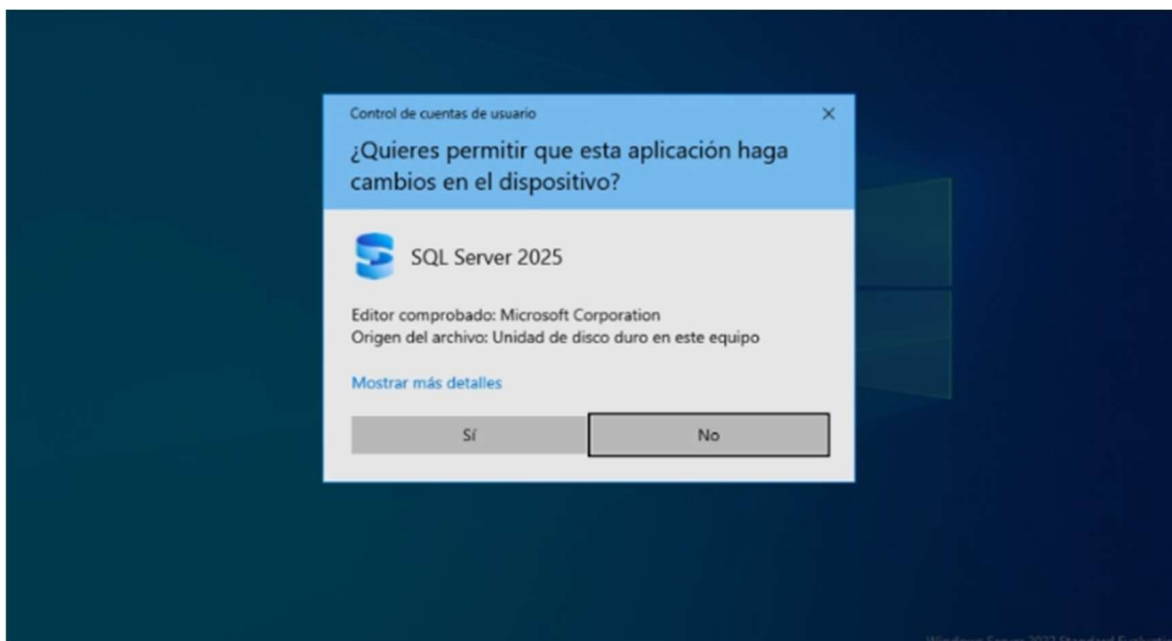


Figura 5. Confirmación del Control de cuentas de usuario antes de iniciar la instalación de SQL Server.

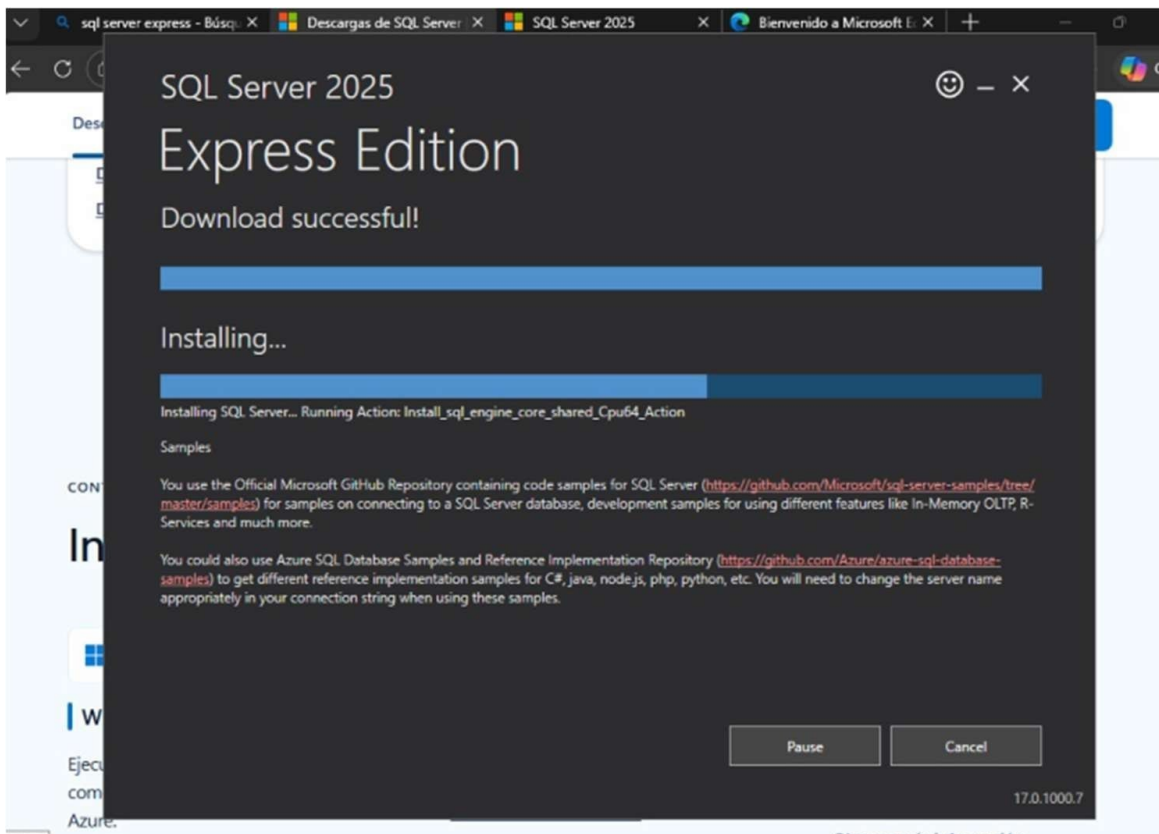


Figura 6. Proceso de instalación de SQL Server Express en el servidor.

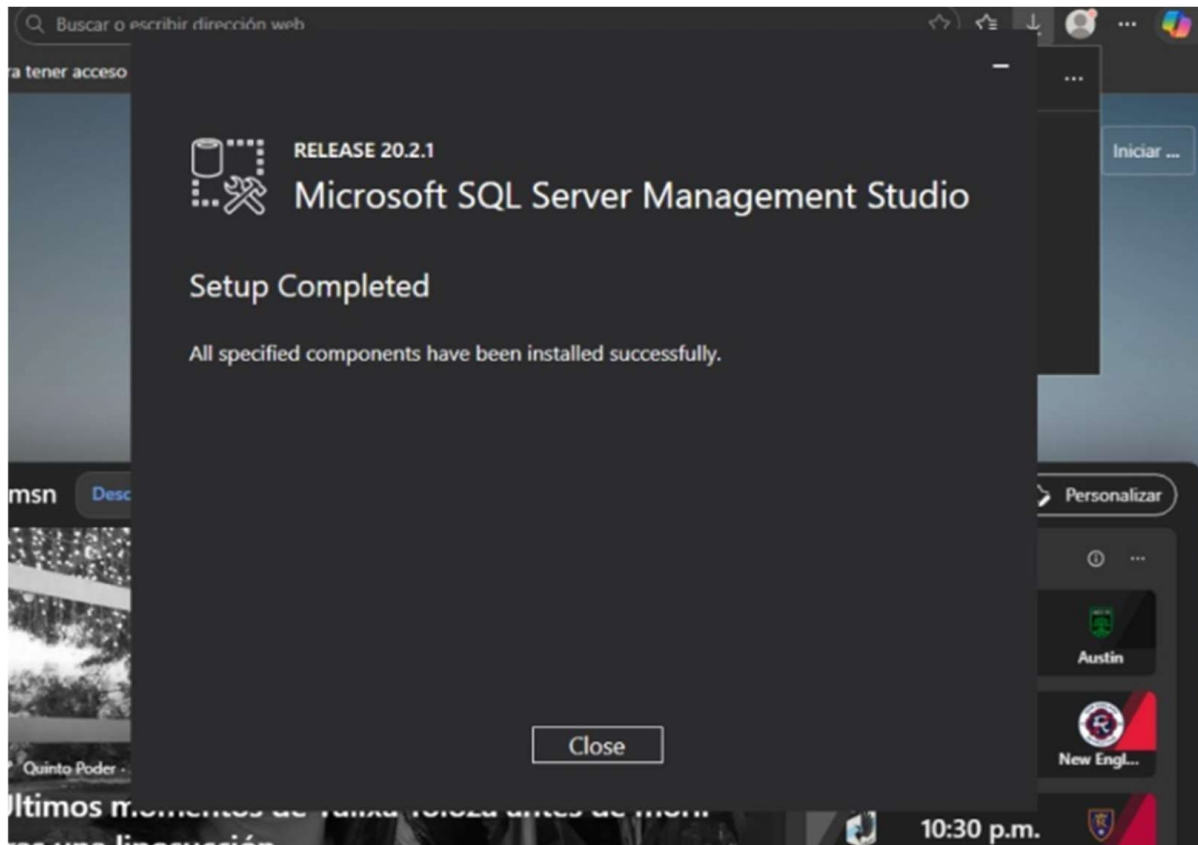


Figura 7. Finalización de la instalación de SQL Server Management Studio.

Después de la instalación, la instancia quedó disponible como WIN-B5N5T8LK3OI\SQLEXPRESS, lo que permitió continuar con la configuración de autenticación, usuarios, base de datos y reglas de conexión.

3.3 Conexión inicial, autenticación mixta y creación de la base de datos

La primera validación en SSMS se realizó conectando a la instancia del motor de base de datos. Para evitar errores de certificado durante las pruebas internas del laboratorio, se configuró el cifrado como Optional y se habilitó Trust server certificate. Posteriormente, desde las propiedades del servidor, se activó el modo de autenticación mixta para permitir tanto autenticación de Windows como autenticación propia de SQL Server.

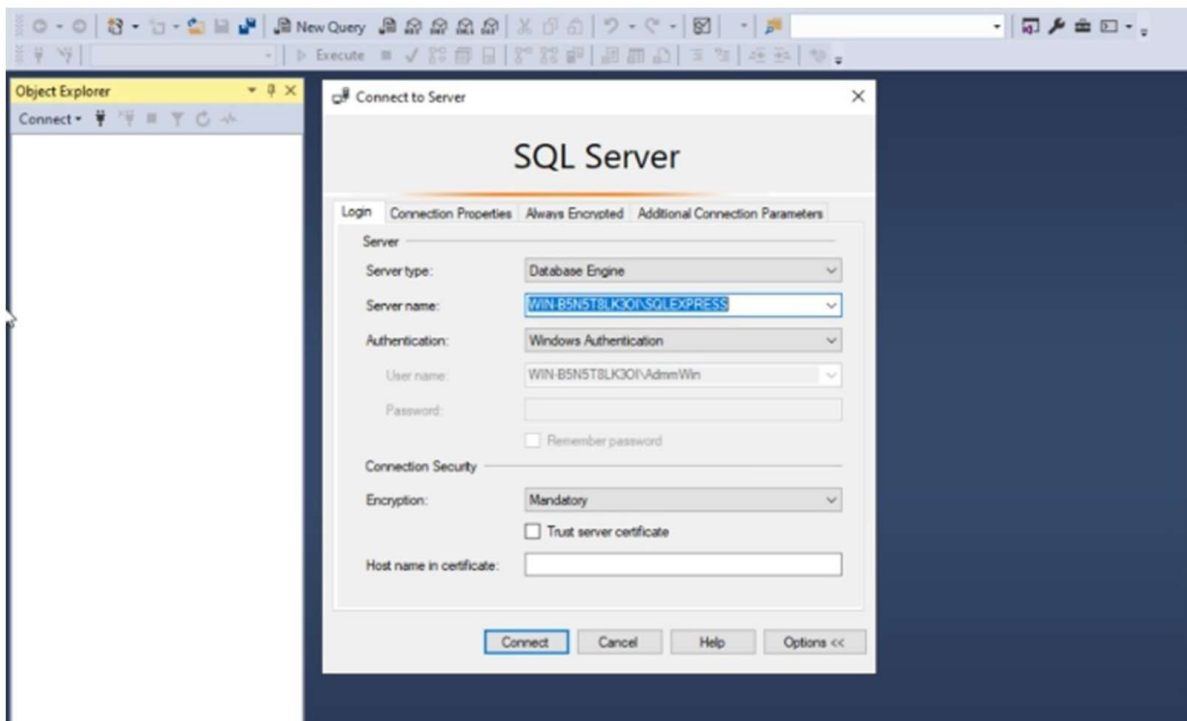


Figura 8. Pantalla de conexión a SQL Server desde SSMS con parámetros de cifrado ajustados para el laboratorio.

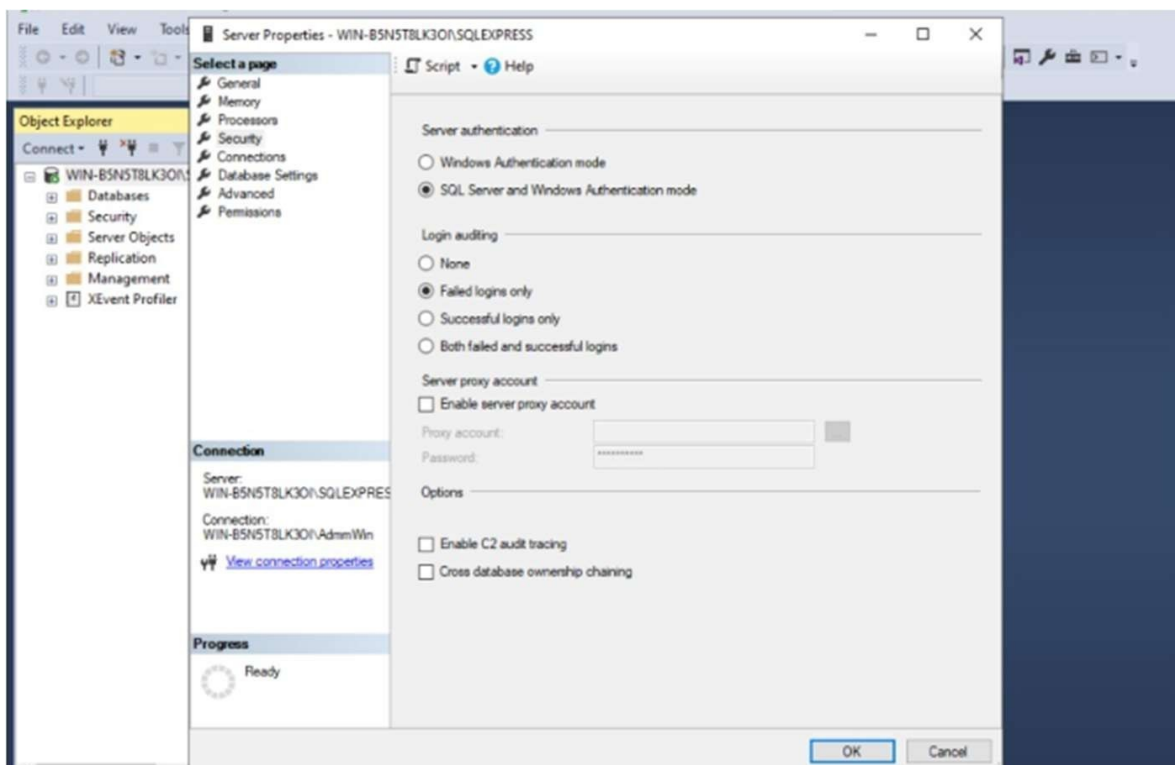


Figura 9. Configuración de seguridad de la instancia para habilitar autenticación mixta y auditoría de inicios de sesión.

Después de aplicar el cambio, se reinició la instancia para que la configuración quedara activa. También se creó la base de datos PracticaHardening, separando el entorno de pruebas del resto de bases del sistema.

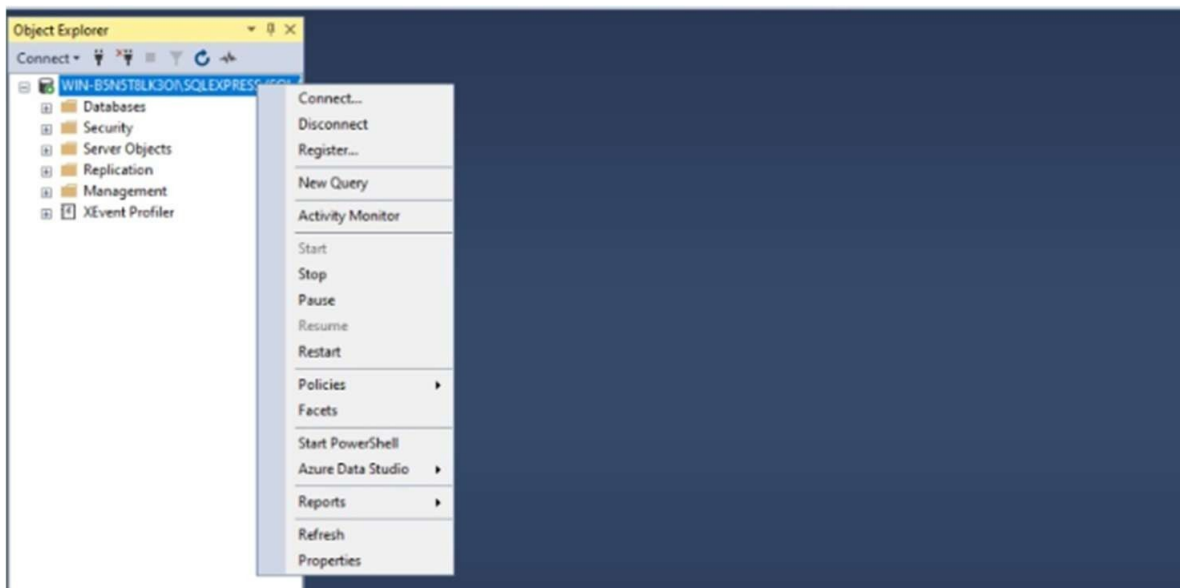


Figura 10. Reinicio de la instancia SQL Server para aplicar los cambios de autenticación.

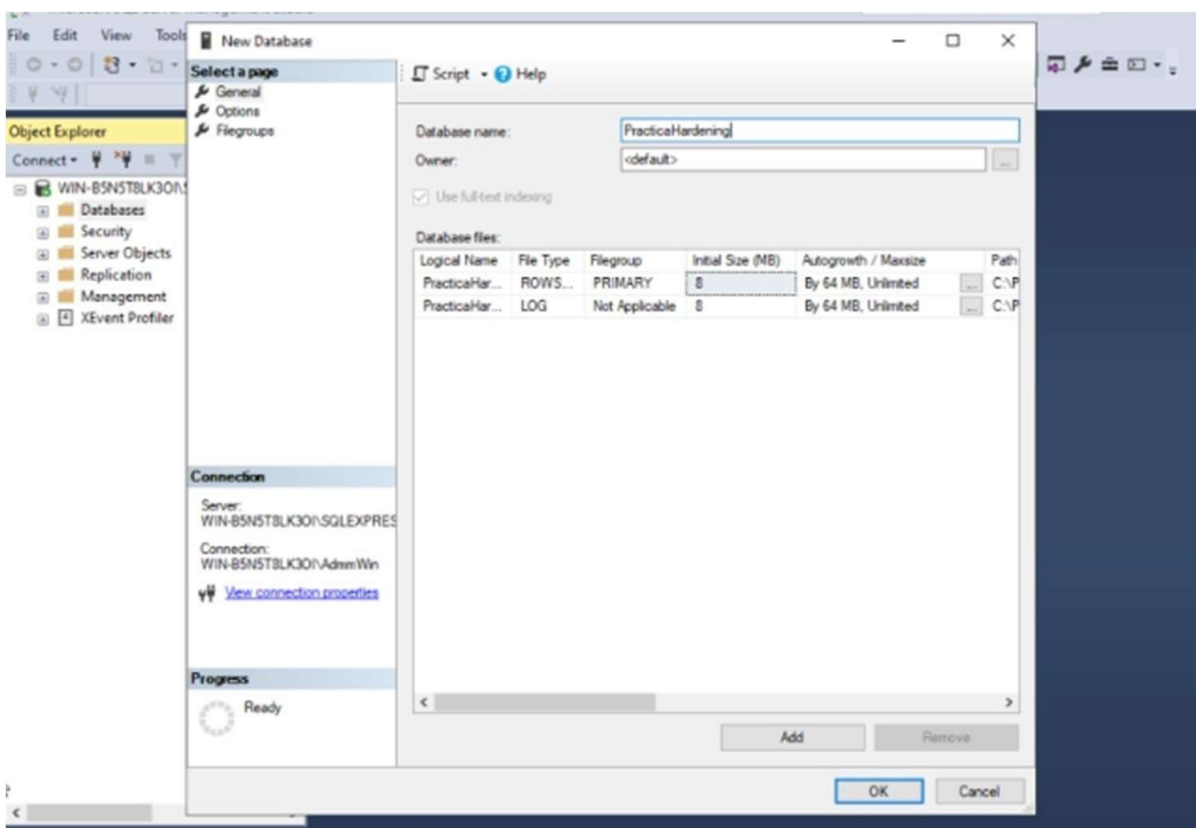


Figura 11. Creación de la base de datos PracticaHardening desde SSMS.

3.4 Creación y configuración de usuarios SQL U1, U2 y U3

Se crearon tres usuarios con autenticación SQL Server y permisos diferenciados, aplicando el principio de menor privilegio. Cada cuenta fue vinculada a la base de datos PracticaHardening y se asignaron roles de acuerdo con la función que debía cumplir dentro del laboratorio.

Usuario	Rol asignado	Uso previsto	Restricción principal
U1_AdminDB	sysadmin	Administración total de la instancia y tareas críticas de mantenimiento	Bloqueo de acceso remoto mediante Logon Trigger; uso administrativo únicamente local
U2_Auth	db_owner	(Autenticación / Autorizado) base de datos, pueda dar de alta.	Funciones están limitadas a tareas de autenticación y dar de alta registros o usuarios.
U3_consulta	db_datareader	Consulta de información sin permisos de escritura ni administración	Acceso de lectura controlado; sin trigger de bloqueo remoto

La separación de cuentas evita utilizar un mismo usuario para todas las actividades. U1 queda destinado a administración de alto privilegio y, por seguridad, se restringe para uso local mediante un Logon Trigger. U2 opera la base de datos PracticaHardening con permisos de administración a nivel de base, mientras que U3 se limita a tareas de consulta con permisos de solo lectura. De esta forma, cada credencial mantiene un alcance claro y controlado según su función.

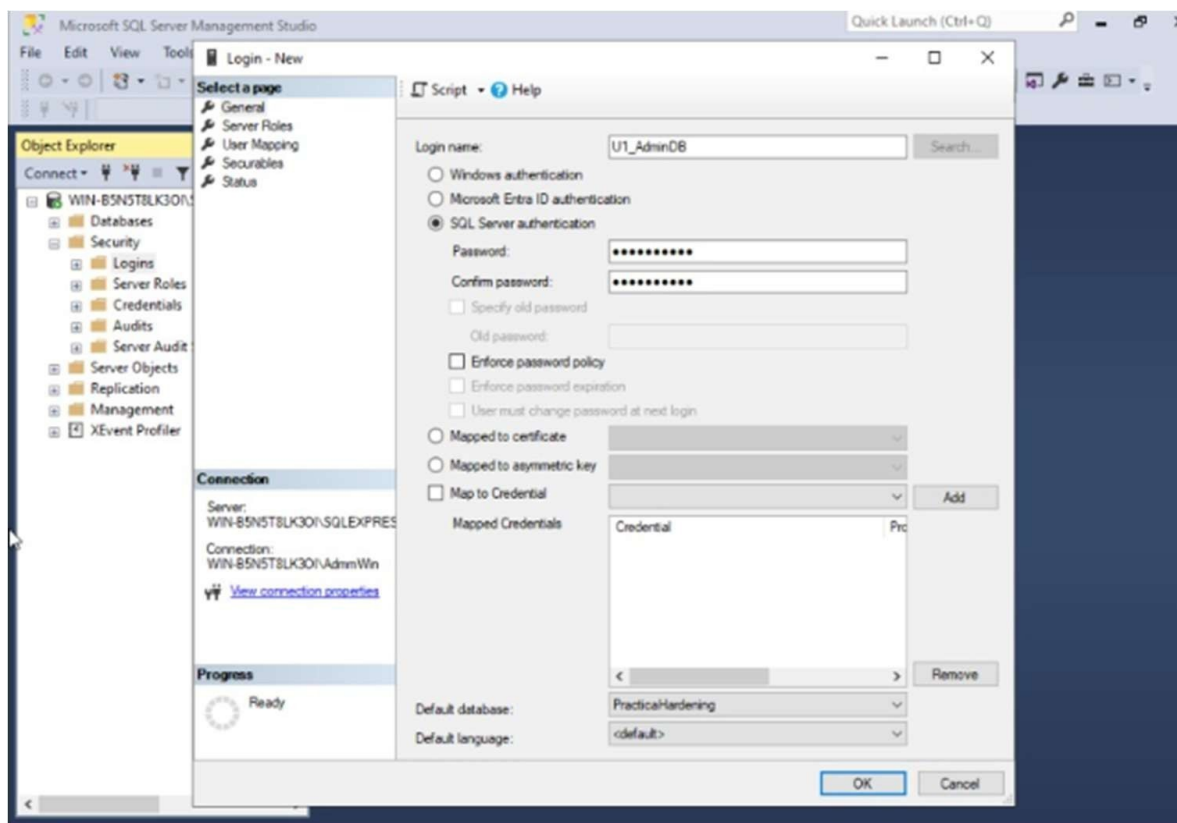


Figura 12. Creación del usuario U1_AdminDB con autenticación SQL Server y base de datos predeterminada.

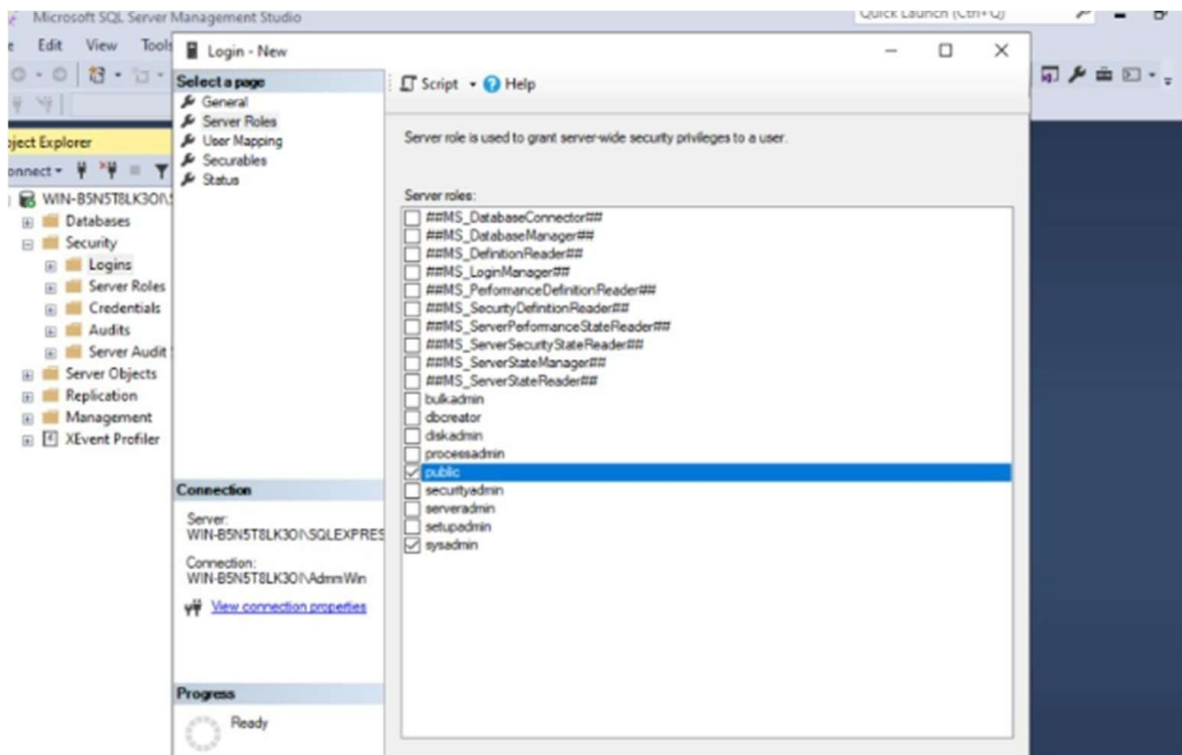


Figura 13. Asignación de rol sysadmin para U1_AdminDB en la instancia de SQL Server.

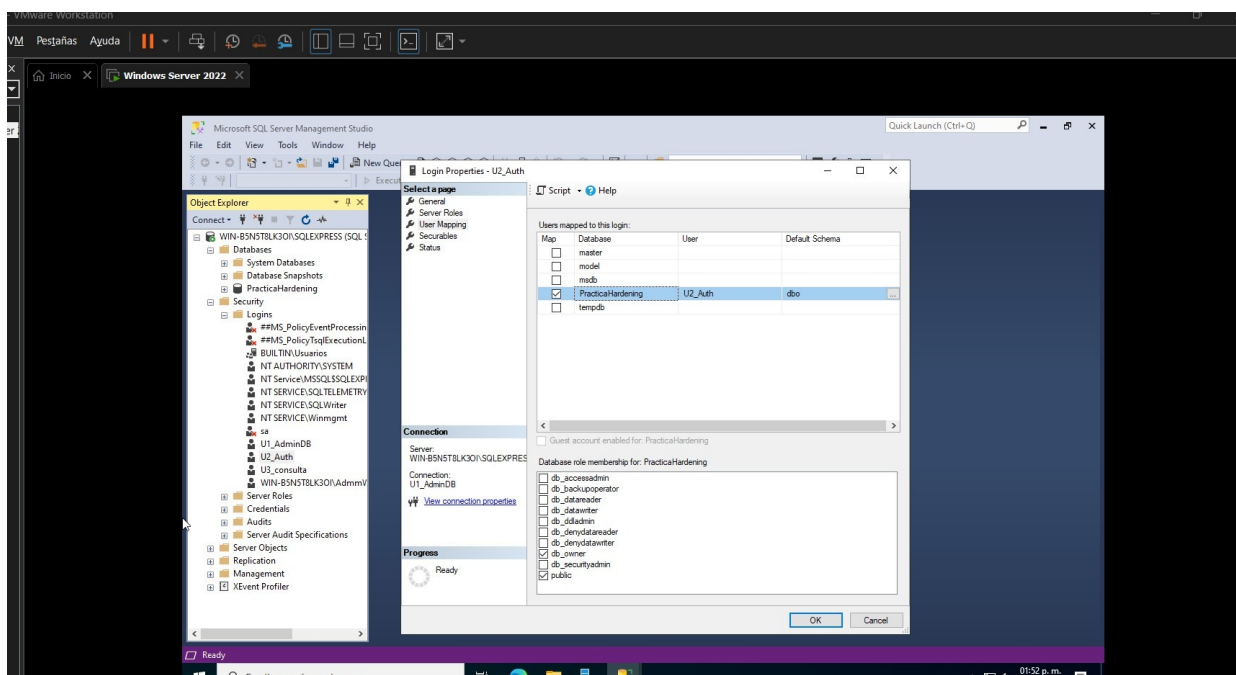


Figura 14. Propiedades del usuario U2_Auth con base de datos predeterminada PracticaHardening.

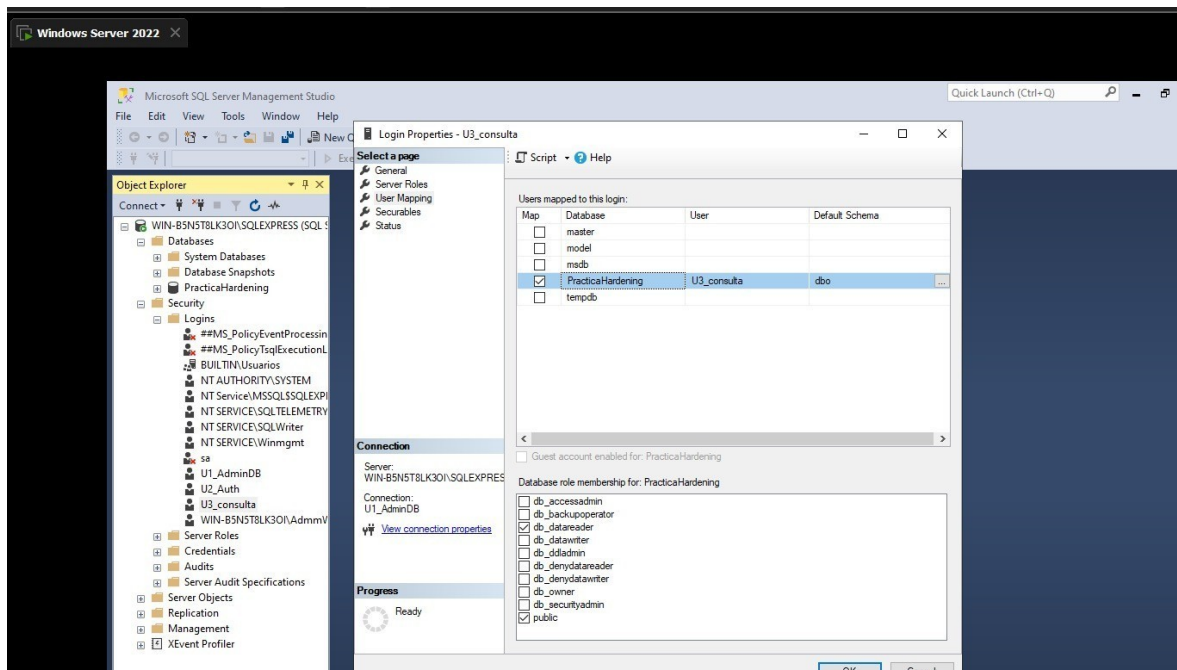


Figura 15. Mapeo del usuario U3_consulta a PracticaHardening con rol db_datareader y esquema dbo.

3.5 Trigger de bloqueo remoto aplicado únicamente a U1_AdminDB

Para cumplir con el control de seguridad para la cuenta administrativa, el bloqueo de acceso remoto se aplicó únicamente al usuario U1_AdminDB. Esta cuenta conserva privilegios elevados sobre la instancia, por lo que su uso debe limitarse al servidor local. El Logon Trigger se ejecuta a nivel servidor, evalúa el usuario autenticado y revisa el origen de la conexión; si detecta que U1_AdminDB intenta iniciar sesión desde un cliente remoto, cancela la sesión mediante ROLLBACK antes de que la conexión quede establecida.

```
CREATE TRIGGER [block_U1_remote]
ON ALL SERVER
FOR LOGON
AS
BEGIN
    IF ORIGINAL_LOGIN() = 'U1_AdminDB'
        AND EVENTDATA().value('(/EVENT_INSTANCE/ClientHost)[1]',
            'NVARCHAR(50)') <> '<local machine>'
    BEGIN
        ROLLBACK;
    END
END;
```

Con esta configuración, U1_AdminDB conserva sus permisos de administración, pero queda protegido contra inicios de sesión remotos no autorizados. U2_Auth y U3_consulta permanecen disponibles de acuerdo con sus roles asignados: U2 para administración de la base PracticaHardening y U3 para consulta de información. Esta combinación refuerza la seguridad porque protege la cuenta más crítica sin afectar las cuentas operativas necesarias para las pruebas remotas.

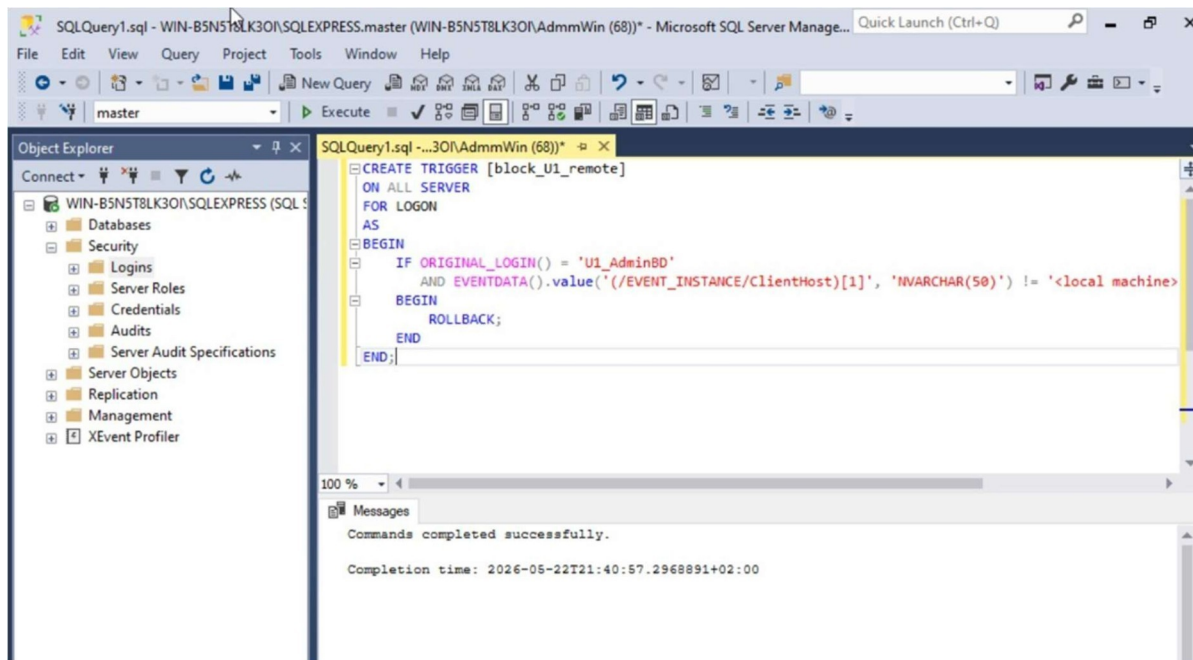


Figura 16. Ejecución del script de Logon Trigger para bloquear el acceso remoto de U1_AdminDB.

3.6 Habilitación del acceso remoto controlado a SQL Server

Para permitir pruebas de conectividad remota de forma controlada, se habilitó el protocolo TCP/IP de SQL Server y se configuró el puerto estático 1433 en IPAll. Esto evita depender de puertos dinámicos y permite alinear la configuración del motor con las reglas del firewall.

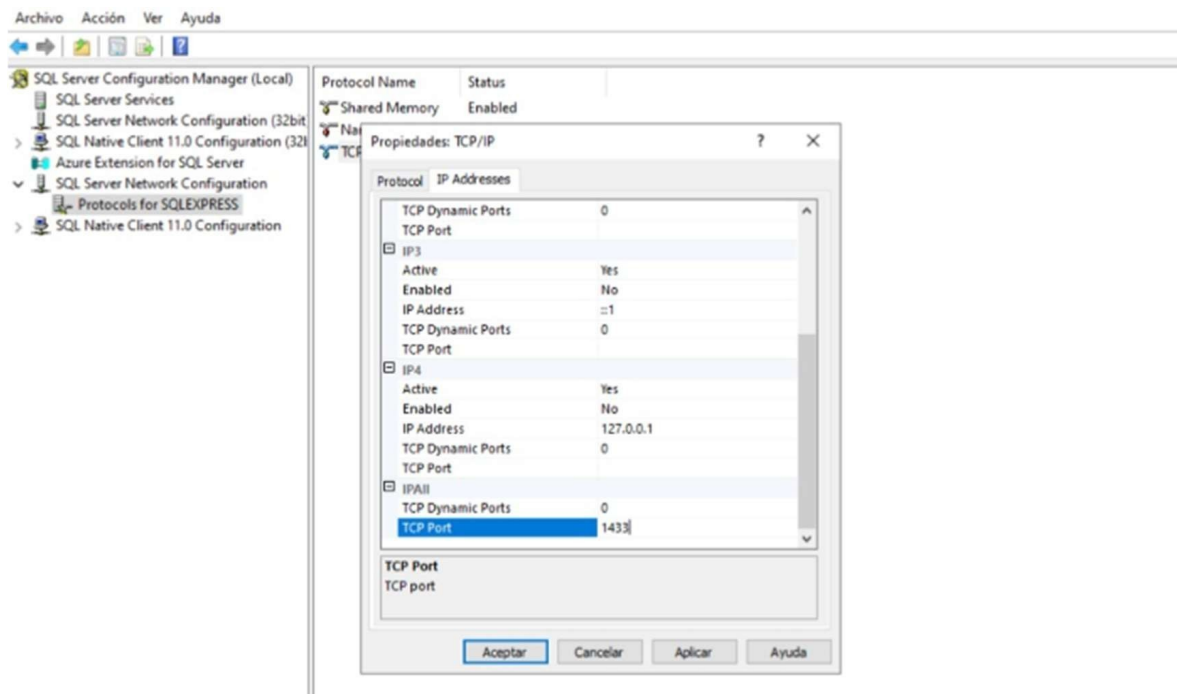


Figura 17. Configuración del puerto TCP 1433 en SQL Server Configuration Manager.

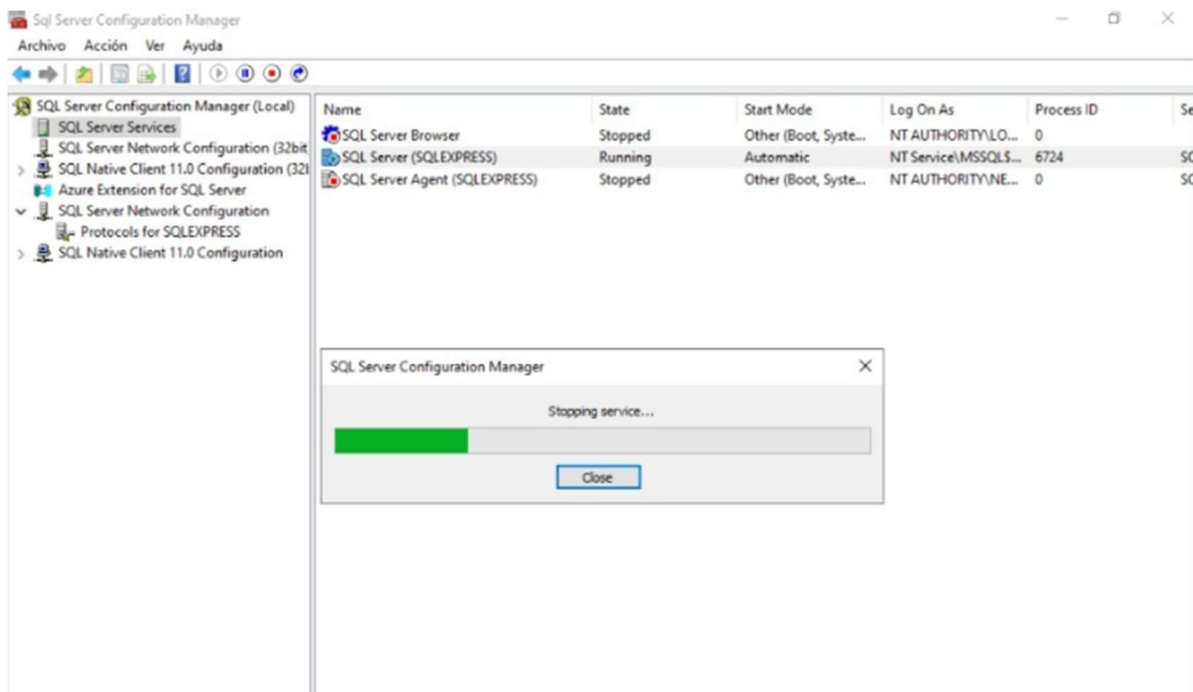


Figura 18. Reinicio controlado del servicio SQL Server para aplicar los cambios de red.

En Windows Defender Firewall se creó una regla de entrada específica para el puerto TCP 1433. La regla permitió únicamente el tráfico necesario para SQL Server, reduciendo la exposición del servidor y manteniendo el resto de servicios bajo las políticas de seguridad del sistema.

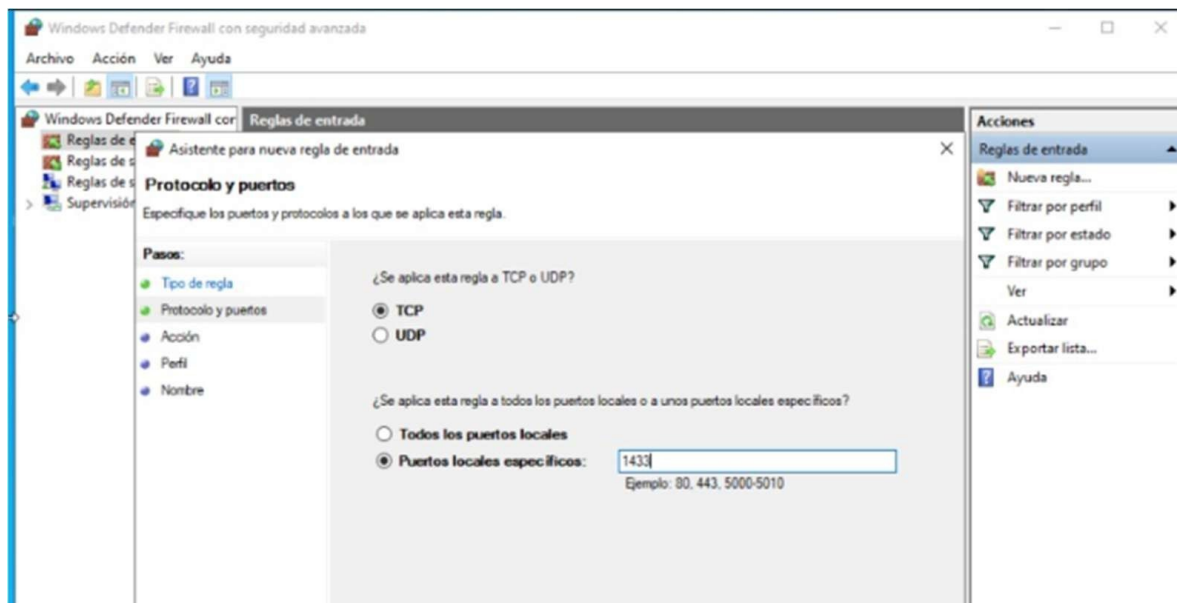


Figura 19. Definición del puerto TCP 1433 en la regla de entrada del firewall.

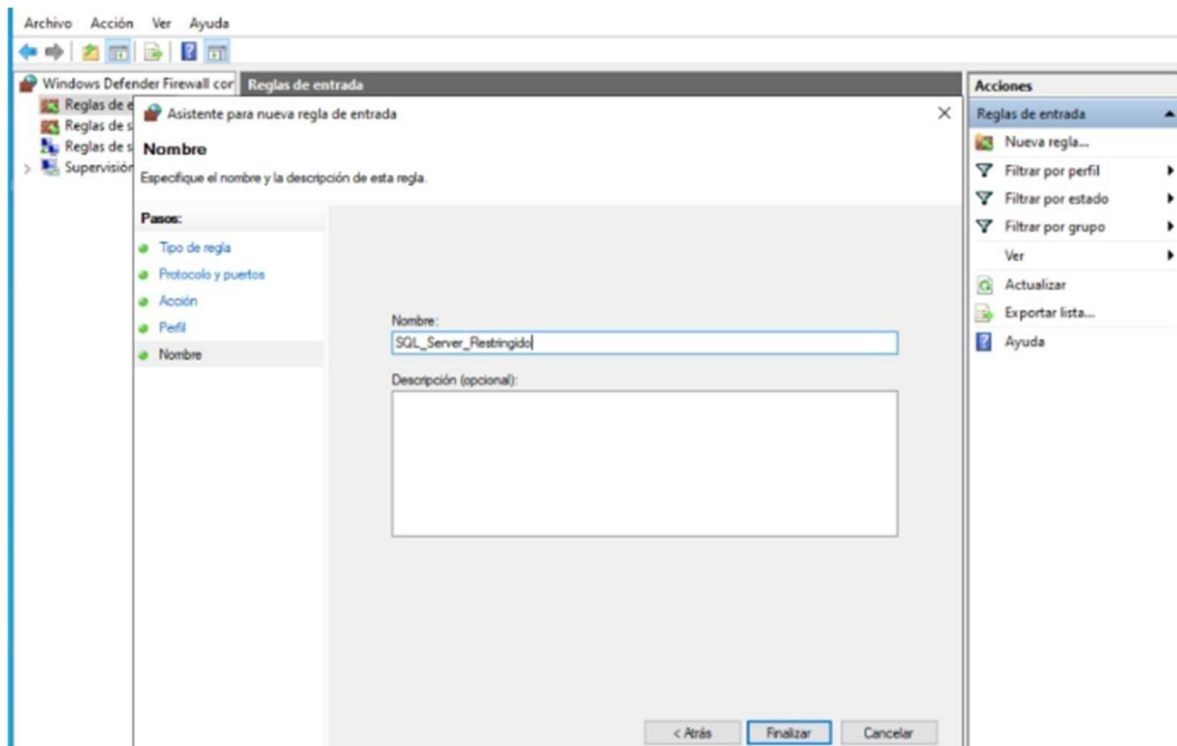


Figura 20. Finalización de la regla de entrada para SQL Server en Windows Defender Firewall.

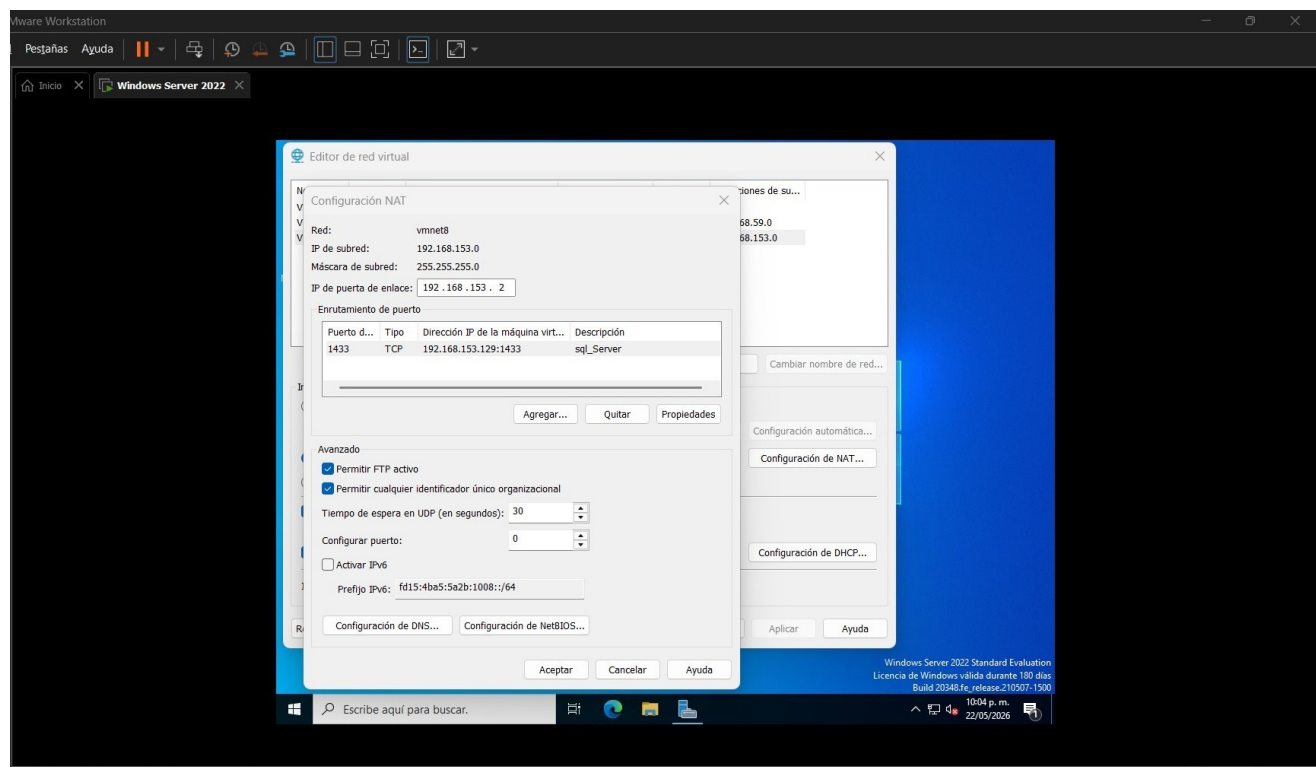
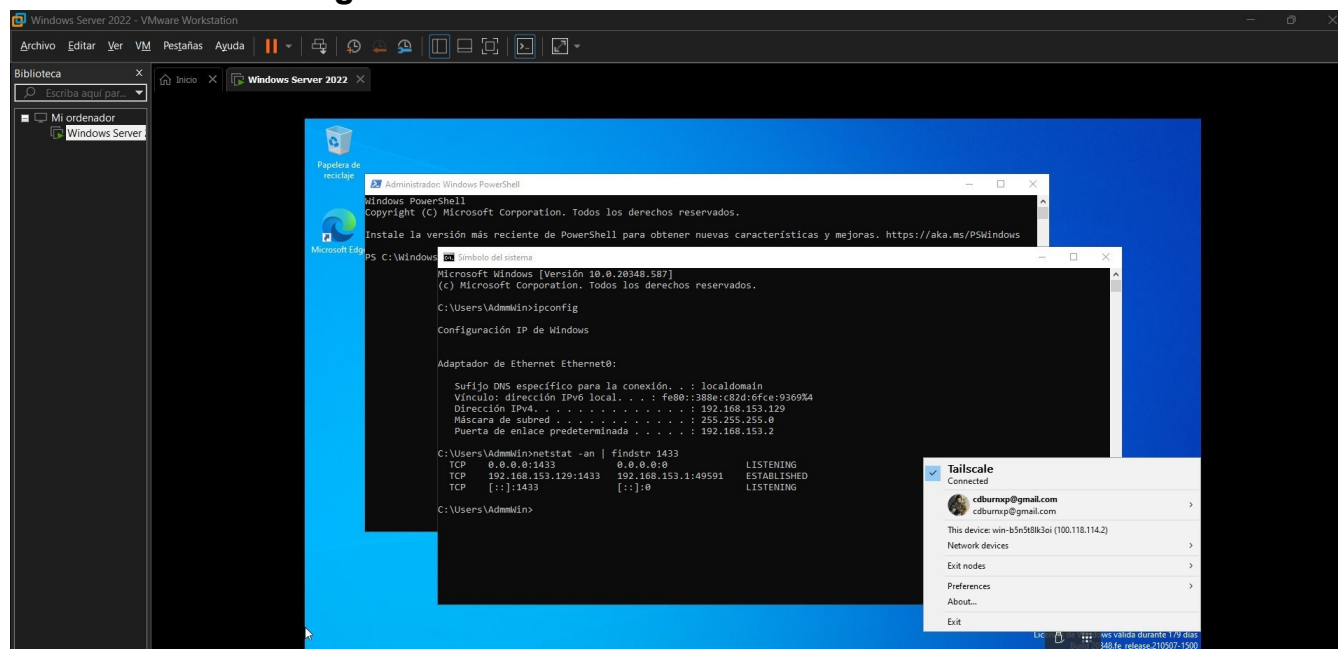


Figura x2. Se configuró Port Forwarding en VMware NAT (puerto 1433 hacia 192.168.153.129)

3.7 Conectividad segura mediante Tailscale desde Linux



Para evitar exponer directamente el servidor a Internet, se utilizó Tailscale como VPN privada entre el servidor Windows y el nodo Debian. Este enfoque permite que los equipos se comuniquen dentro de una red privada autenticada, sin abrir servicios críticos a redes públicas. En el servidor Linux se verificó el estado de la tailnet mediante el comando `tailscale status`, donde se observa el nodo Debian y el servidor Windows registrado en la red privada.

Figura 21. Configuración de Tailscale en Windows Server para habilitar la comunicación privada con el nodo Debian.



Figura 22. Validación en Linux mediante `tailscale status`, mostrando el nodo Debian y el servidor Windows dentro de la tailnet.

La captura evidencia que Tailscale se encuentra instalado y configurado en Linux. Windows también se encuentra conectado, queda registrado dentro de la red privada, lo cual confirma la integración de ambos equipos para las pruebas de conectividad segura.

3.8 Pruebas de autenticación y acceso con usuarios configurados

Una vez creadas las cuentas, se realizaron pruebas desde SSMS y posteriormente desde el servidor Debian conectado por Tailscale. La validación remota se realizó con `sqlcmd` apuntando a la IP privada de Tailscale del servidor Windows y al puerto 1433, permitiendo comprobar el comportamiento real de cada usuario fuera del equipo local.

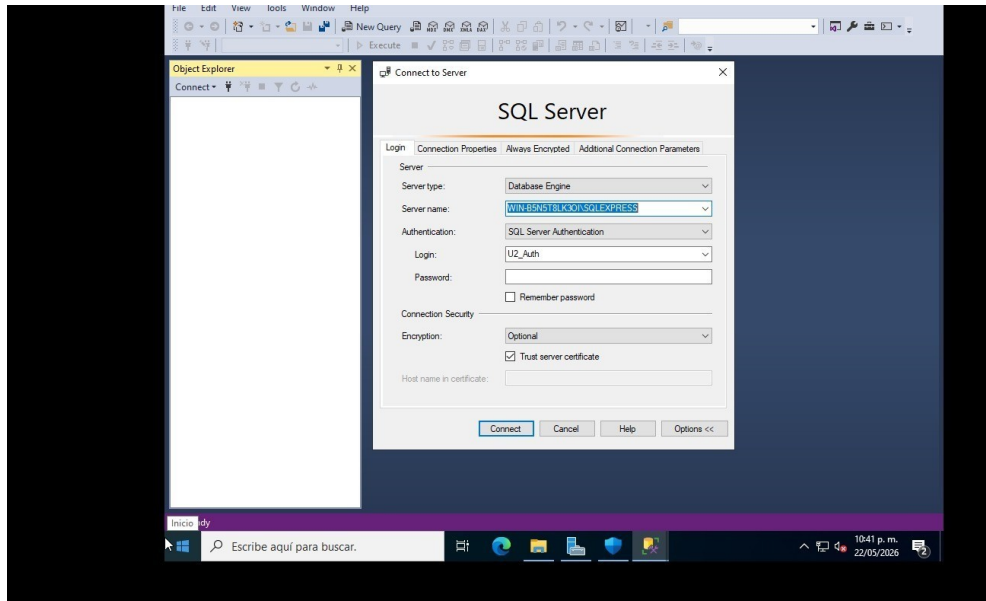


Figura 23. Prueba de conexión en SSMS usando el usuario U2_Auth.

Usuario	Validación esperada	Resultado documentado
U1_AdminDB	Debe iniciar localmente, pero fallar al conectarse desde Debian/Tailscale por el Logon Trigger	Login failed for user U1_AdminDB desde Debian; bloqueo remoto correcto
U2_Auth	Debe conectarse de forma local y remota a PracticaHardening con permisos de db_owner	Conexión remota correcta; sqlcmd muestra prompt 1>
U3_consulta	Debe conectarse de forma local y remota con permisos de solo lectura	Conexión remota correcta; sqlcmd muestra prompt 1> y rol db_datareader confirmado

La prueba remota confirma que el trigger protege específicamente a U1_AdminDB: al intentar iniciar sesión desde Debian, SQL Server rechaza la autenticación con el mensaje Login failed. En cambio, U2_Auth y U3_consulta logran abrir sesión correctamente y muestran el prompt 1>, evidenciando que el puerto, la VPN y los permisos de cada cuenta funcionan según lo esperado.

```

https://login.tailscale.com/a/18a2bb6b01f1eb
Dropshipping vs SaaS para nego...
Success.
admin@debian-ici:~$ sqlcmd -S 100.118.114.2,1433 -U U1_AdminBD -P 'Admin1234!' -No -C
Sqlcmd: Error: Microsoft ODBC Driver 18 for SQL Server : Login failed for user 'U1_AdminBD'..
admin@debian-ici:~$ sqlcmd -S 100.118.114.2,1433 -U U2_Auth -P 'Auth1234!' -No -C
1> exit
admin@debian-ici:~$ sqlcmd -S 100.118.114.2,1433 -U U3_Consulta -P 'Query1234!' -No -C
1>

```

Figura 24. Prueba remota desde Debian mediante sqlcmd: U1_AdminDB es bloqueado y U2_Auth/U3_consulta conectan correctamente.

```

PS C:\Users\castr> sqlcmd -S 192.168.153.129,1433 -U U1_AdminBD -P "Admin1234!" -No -C
mssql: login error: Login failed for user 'U1_AdminBD'.
mssql: login error: Login failed for user 'U1_AdminBD'.
PS C:\Users\castr> sqlcmd -S 192.168.153.129,1433 -U U2_Auth -P "Auth1234!" -No -C
1> exit
PS C:\Users\castr> sqlcmd -S 192.168.153.129,1433 -U U3_Consulta -P "Query1234!" -No -C
1>

```

Figura 25. Validación adicional desde Windows Host mediante sqlcmd para confirmar el comportamiento de los usuarios.

```

admny@debian-ici:~$ sqlcmd -S 100.118.114.2,1433 -U U2_Auth -P 'Auth1234!' -d PracticaHardening -No -C
1> CREATE TABLE prueba_permisos_u2 (
2> id INT IDENTITY(1,1) PRIMARY KEY,
3> descripcion VARCHAR(100),
4> fecha DATETIME DEFAULT GETDATE()
5> );
6> GO
1> INSERT INTO prueba_permisos_u2 (descripcion)
2> VALUES ('Prueba de escritura realizada desde Debian con U2_Auth');
3> GO

(1 rows affected)
1> SELECT * FROM prueba_permisos_u2;
2> GO

```

id	descripcion	fecha
1	Prueba de escritura realizada desde Debian con U2_Auth	2026-05-29 18:17:21.727

```

(1 rows affected)
admny@debian-ici:~$ sqlcmd -S 100.118.114.2,1433 -U U2_Auth -P 'Auth1234!' -d PracticaHardening -No -C
1> CREATE LOGIN prueba_servidor_u2 WITH PASSWORD = 'Temp1234!';
2> GO
Msg 15247, Level 16, State 1, Server WIN-B5N5T8LK30I\SQLEXPRESS, Line 1
User does not have permission to perform this action.

```

Figura 4x. Probamos U2 añadiendo una tabla y un registro tambien intentamos crear un usuario a nivel servidor y por su rol no deja hacer el registro del usuario

```

admny@debian-ici:~$ sqlcmd -S 100.118.114.2,1433 -U U3_consulta -P 'Query1234!' -d PracticaHardening -No -C
1> SELECT * FROM prueba_permisos_u2;
2> GO

```

id	descripcion	fecha
1	Prueba de escritura realizada desde Debian con U2_Auth	2026-05-29 18:17:21.727

```

(1 rows affected)
1> INSERT INTO prueba_permisos_u2 (descripcion)
2> VALUES ('Intento de escritura desde Debian con U3_consulta');
3> GO
Msg 229, Level 14, State 5, Server WIN-B5N5T8LK30I\SQLEXPRESS, Line 1
The INSERT permission was denied on the object 'prueba_permisos_u2', database 'PracticaHardening', schema 'dbo'.
1>

```

Figura 5x. Probamos U3 para visualizar una tabla y al intentar insertar no no deja por el rol que desempeña

3.9 Respaldo de la base de datos y almacenamiento local controlado

Como parte de la continuidad operativa, se generó un respaldo completo de la base de datos PracticaHardening. El archivo fue almacenado fuera de la ruta predeterminada del motor, utilizando el directorio C:\Backups para mantener una ubicación controlada y fácil de auditar.

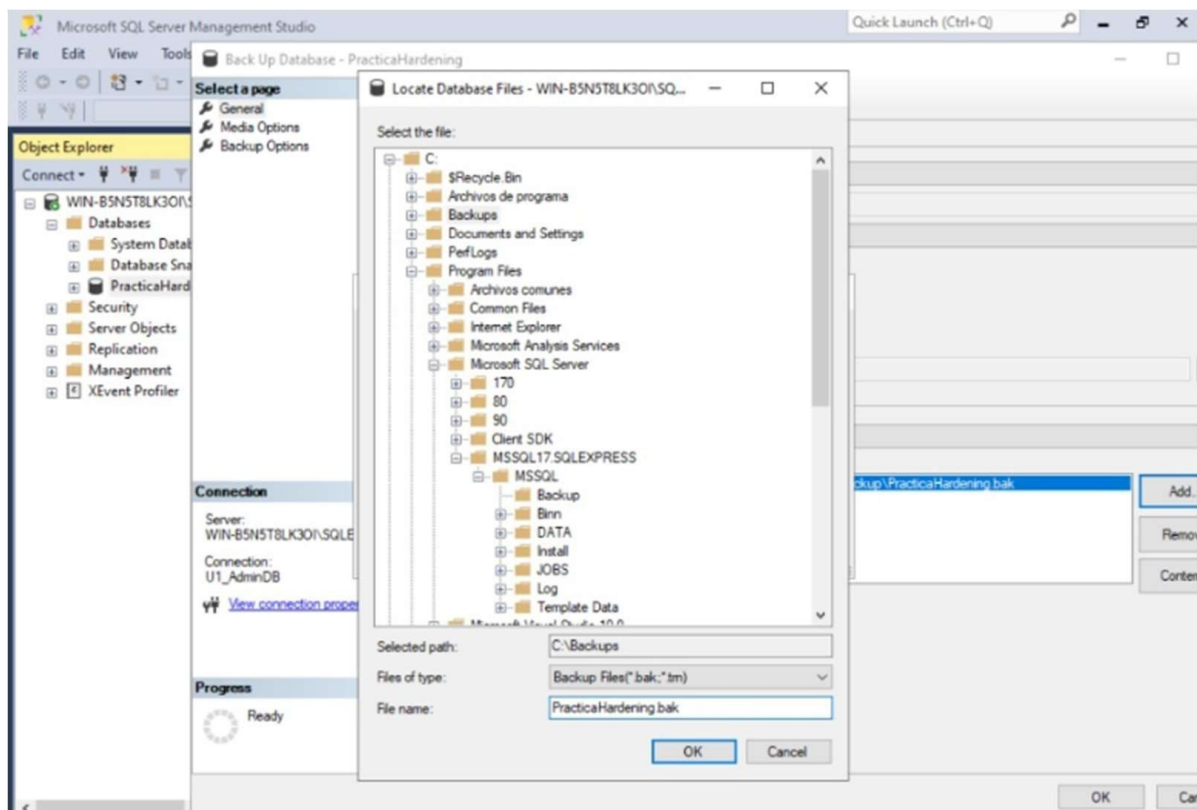


Figura 26. Selección del destino físico del respaldo en la ruta C:\Backups.

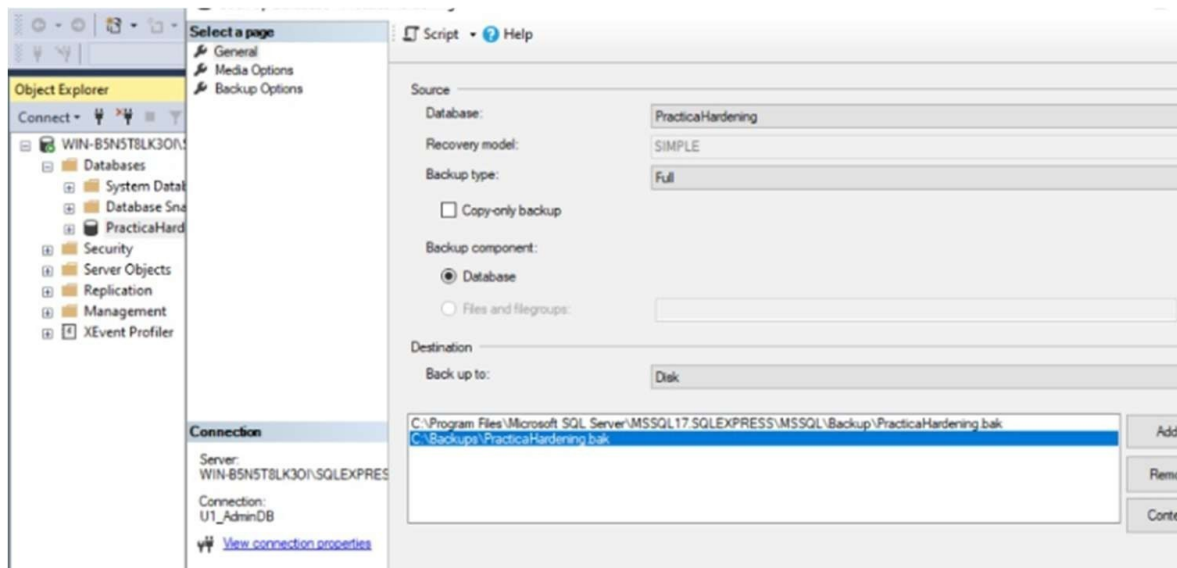


Figura 27. Configuración final del respaldo de PracticaHardening desde SSMS.

Esta decisión permite separar los archivos de respaldo del directorio interno del motor de SQL Server, facilitando su transferencia hacia otros medios y reduciendo el riesgo de pérdida si se presenta una falla en la estructura principal de la instancia.

3.10 Automatización del respaldo mediante Programador de tareas

Para automatizar el respaldo se creó una tarea programada en Windows Server. La tarea ejecuta un script de PowerShell encargado de generar el archivo .bak de PracticaHardening, enviarlo al servidor Debian mediante SCP y, desde el mismo flujo, ordenar la copia hacia Google Drive con rclone. De esta manera se evita depender de pasos manuales y se mantiene una cadena de respaldo repetible, auditable y alineada con la regla 3-2-1.

```
& "C:\Program Files\Microsoft SQL Server\Client SDK\ODBC\180\Tools\Binn\SQLCMD.EXE" -S
localhost\SQLEXPRESS -E -No -C -Q "BACKUP DATABASE PracticaHardening TO DISK='C:
\Backups\PracticaHardening.bak' WITH FORMAT, INIT"
scp -P 12222 C:\Backups\PracticaHardening.bak admnyc@159.223.152.22:/home/admnyc/
ssh -p 12222 admnyc@159.223.152.22 "rclone copy /home/admnyc/PracticaHardening.bak gdrive:
```

Fragmento 1. Script de PowerShell usado para generar el .bak, enviarlo al servidor Debian y sincronizarlo con Google Drive.

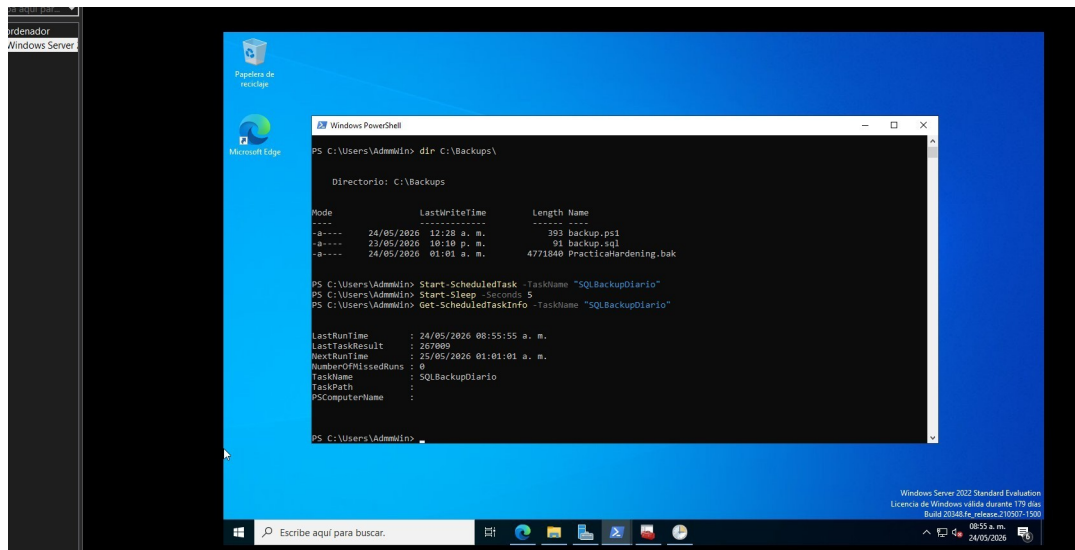


Figura 28. Preparación y revisión del script de respaldo en Windows Server antes de ejecutar la transferencia.

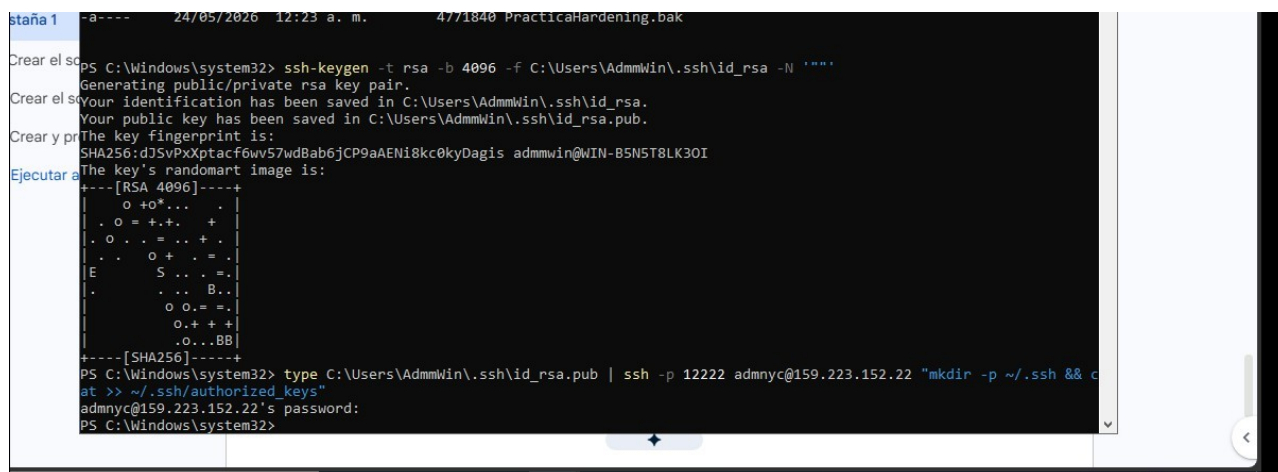


Figura x3. Creamos un ssh keygen para que windows pueda entrar sin contraseña a server debian

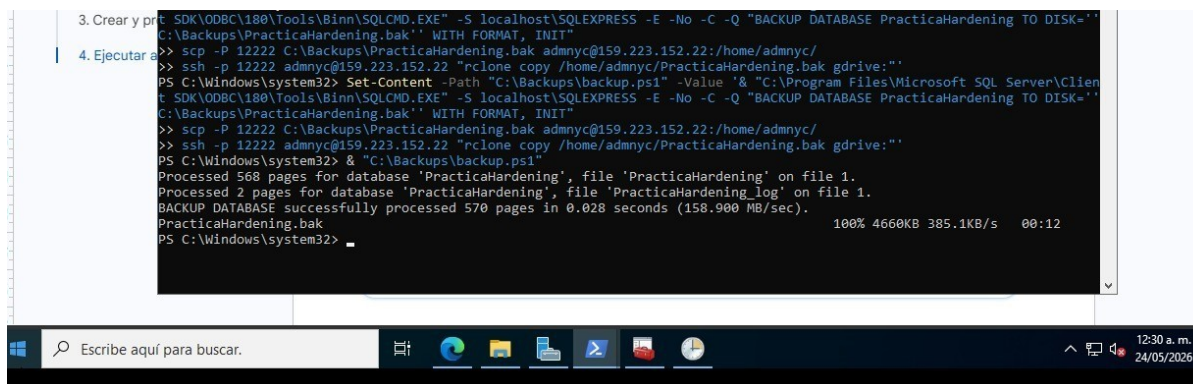


Figura 29. Ejecución del script: SQL Server genera el respaldo y SCP transfiere PracticaHardening.bak al servidor Debian y Google Drive nos pedira acceso solo la primera vez por contraseña despues se hara automatico.

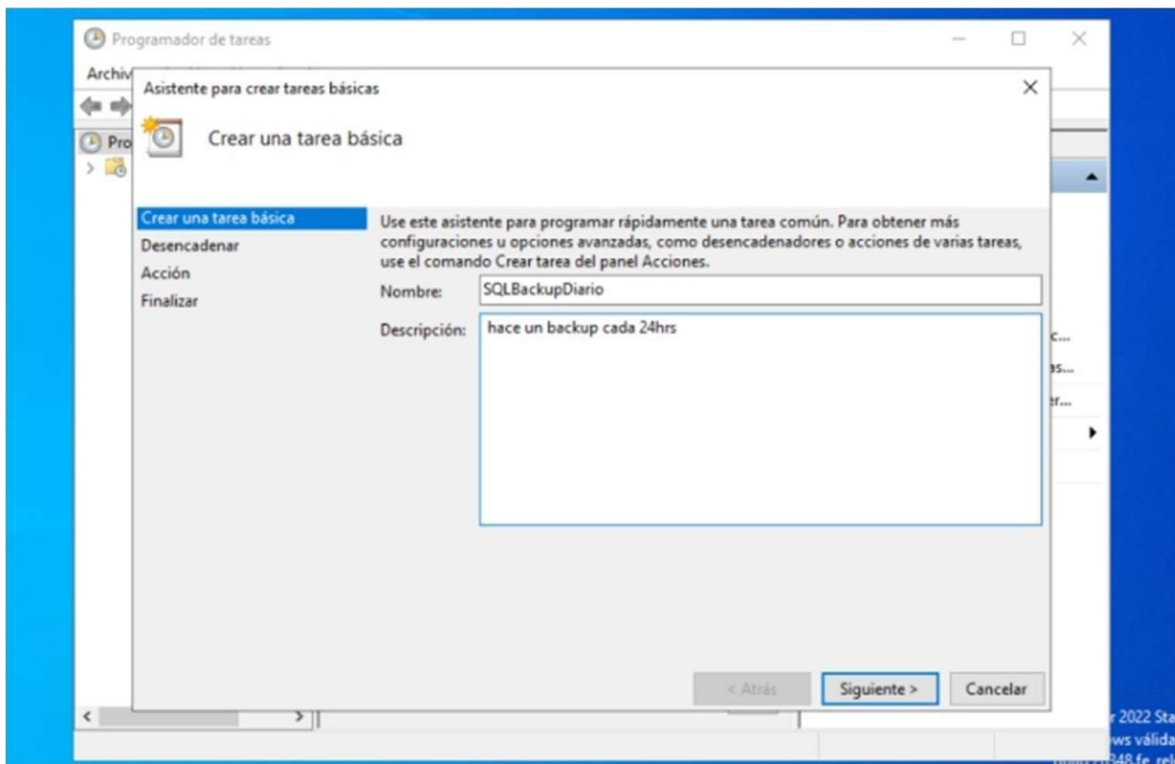


Figura 30. Inicio del asistente del Programador de tareas para crear la tarea de respaldo automático.

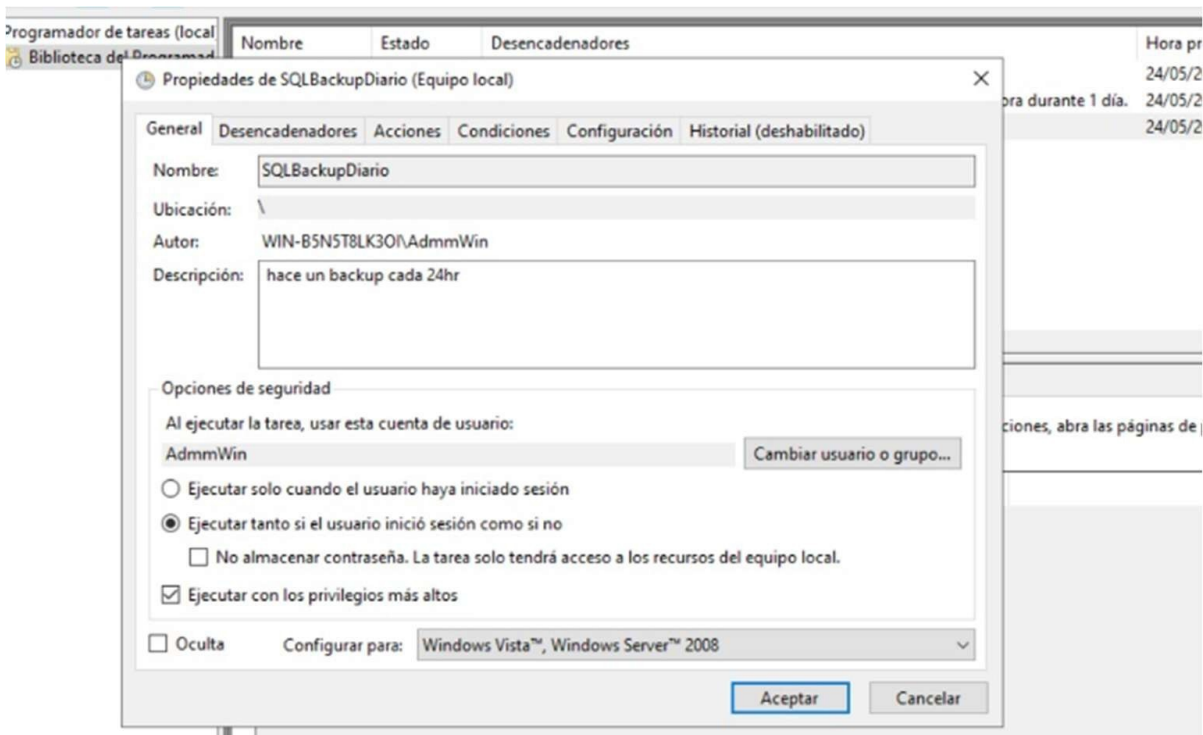


Figura 31. Propiedades de la tarea SQLBackupDiario con ejecución privilegiada y parámetros de seguridad.

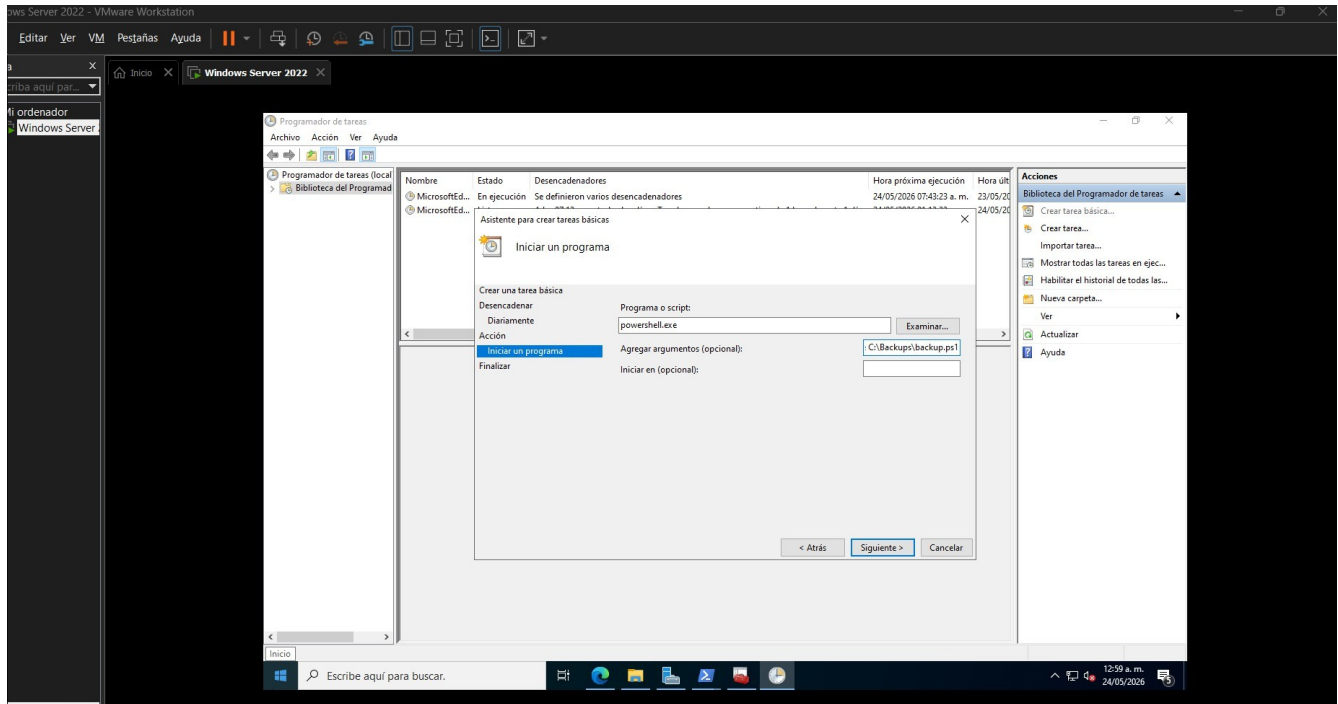


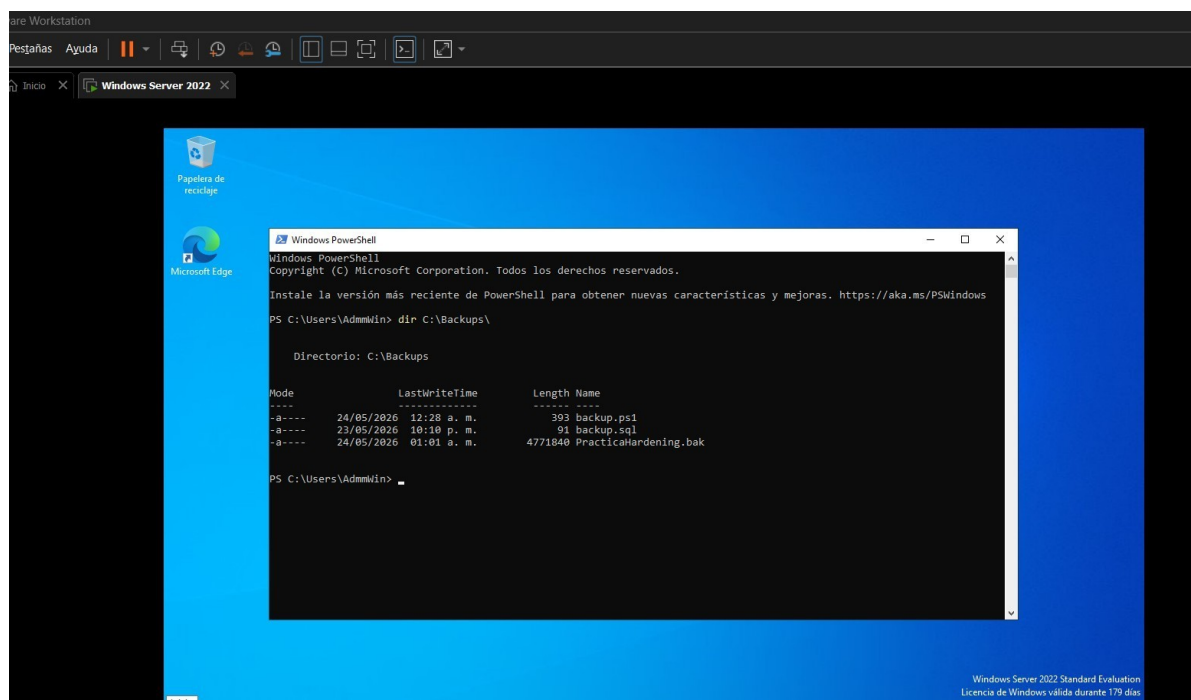
Figura 32. Configuración de la acción de la tarea para ejecutar el script de respaldo en PowerShell.

El flujo automatizado cumple la regla 3-2-1: una copia local en Windows Server, una copia remota en el servidor Debian y una copia fuera de sitio en Google Drive.

Figura 33. Resumen final de la tarea programada con ejecución diaria del respaldo automático.

3.11 Validación del respaldo 3-2-1 en Debian y Google Drive

La validación se realizó desde el servidor Debian y desde Google Drive. Primero se comprobó que el archivo PracticaHardening.bak estuviera presente en /home/admnyc/ con tamaño actualizado; después se verificó con rclone que la copia fuera de sitio también estuviera disponible en la unidad remota. Esta



revisión cerró el ciclo completo: respaldo local en Windows, copia en Linux y copia externa en Google Drive.

```
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent permitted by applicable law.
admny@debian-ici:~$ ls -lh ~/PracticaHardening.bak
-rw-rw-r-- 1 admny admny 4.6M may 24 01:33 ~/PracticaHardening.bak
admny@debian-ici:~$ rclone ls gdrive: | grep PracticaHardening
4771840 PracticaHardening.bak
admny@debian-ici:~$
```

Figura 34. Verificación del archivo PracticaHardening.bak en Debian mediante comandos de consola.

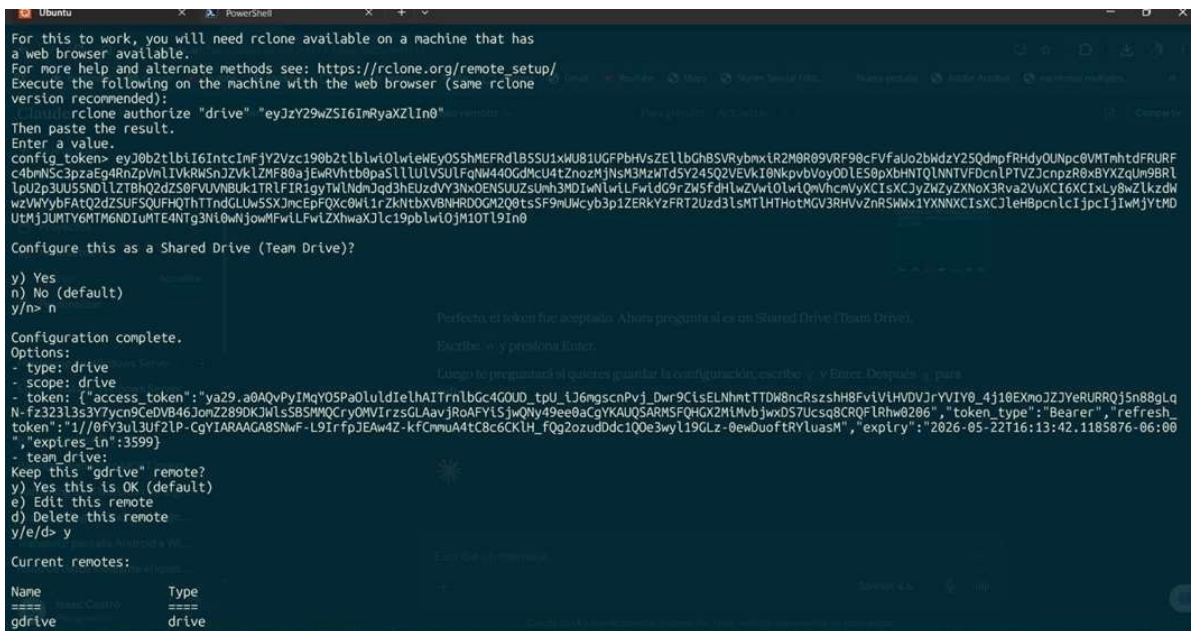


Figura 35. Revisión de configuración y transferencia del respaldo hacia almacenamiento remoto.

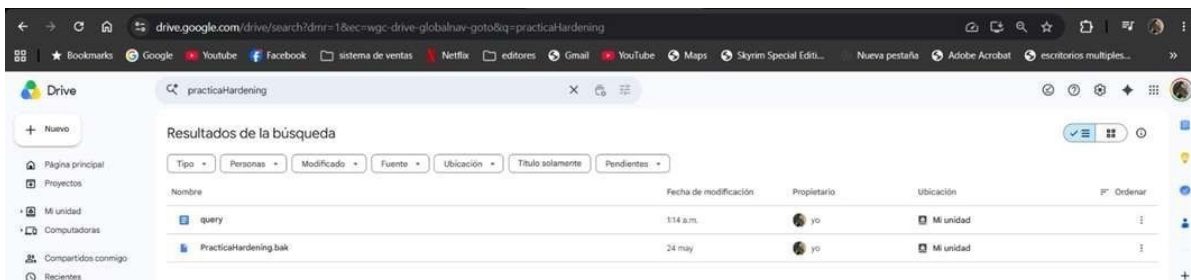


Figura 36. Confirmación visual del archivo de respaldo en Google Drive.

Con esta evidencia se confirma que el proceso de respaldo no quedó limitado al servidor local. El archivo fue generado en Windows Server, transferido al servidor Debian y resguardado fuera de sitio en Google Drive, aumentando la resiliencia ante fallos del servidor, corrupción de datos o pérdida del entorno virtualizado.

Nota: El server tiene una variación de tiempo ala zona horaria desde Madrid se ubica en UTC+1 durante el invierno y UTC+2 durante el horario de verano. Por lo tanto, Madrid está entre 7 y 8 horas más adelantada a CDMX UTC-6 (Hora del Centro),

4. Conclusión

La práctica permitió estructurar un proceso integral de hardening para Windows Server 2022 y SQL Server Express. Se inició con la revisión del entorno administrativo, se instaló y configuró el motor de base de datos, se habilitó la autenticación mixta y se creó una base de datos independiente para las pruebas de seguridad.

La separación de usuarios U1, U2 y U3 fortaleció el control de accesos porque cada cuenta quedó asociada a una función específica. U1_AdminDB conserva la administración de la instancia, pero su uso remoto queda bloqueado mediante un Logon Trigger; U2_Auth administra la base PracticaHardening con permisos db_owner; y U3_consulta queda limitado a lectura mediante db_datareader. Esta distribución permite comprobar el principio de menor privilegio sin perder funcionalidad operativa en las pruebas remotas.

La conectividad con Tailscale permitió validar un enfoque más seguro que la exposición directa de puertos a Internet, mientras que el esquema de respaldo 3-2-1 aseguró la existencia de copias en el servidor, en Linux y en Google Drive. Con ello, el entorno queda documentado, funcional y preparado para justificar técnicamente cada medida implementada.